

7.15 audit unit 07b2 — groups, iteration and optional visibility

1. Identity and frozen scope

Owner: 7.15 firmware rehearsal. Worktree: /private/tmp/kk715-stack07b2, branch release/715-stack-07b2-erc7730-groups, [firmware draft #866](https://github.com/BitHighlander/keepkey-firmware/pull/866). Target: release/715-stack-07b1-erc7730-formatters at 5c0090e038769ed36d627d4dca09cbfcb1df91d3. Code predecessor before this report: 2020f2e88222e6cc8b37f7638d977b61cbc375d0. Predecessor reconciliation after A's wire correction: b07f14ad79389326cd73cf7a72a43cadbf1614d1. D wire-title expectation correction: 237ecc8db07a6550c29302acab5c333fc8cb5765. Copilot round 1 source correction: 4078759de94c3a3d2013959fc1086a5d2f5e0d30. Copilot round 3 fixed-array wire control: 98bf4d20f. Python companion: deps/python-keepkey at 9ded843, [companion draft #115](https://github.com/BitHighlander/python-keepkey/pull/115). The main-worktree MASTER-AUDIT-TEMPLATE.md SHA256 is 743843a17139a7394325a961b9a38666c8e8af7a0005e0ff52eb94559ec8dbb7. This is a code-bearing adjacent PR diff. It adds D behavior to the accepted A-C predecessor; E embedded-call dispatch belongs to the following unit.

Groups structure fields without hiding them. An iteration walks exactly one array, reached through tuples, in a calldata definition. Every field inside must read that active array, so a scalar cannot be repeated for each element. Only the optional condition runs, and it always shows the field. All visibility rules that could hide a field are refused at preload. The host mirror makes the same decisions.

2. Git inventory and changed behavior

Immutable code inventory range: git diff --numstat 5c0090e038769ed36d627d4dca09cbfcb1df91d3..98bf4d20f. Frozen inventory range including this source report and PDF: git diff --numstat 5c0090e038769ed36d627d4dca09cbfcb1df91d3..FROZEN_RANGE_PENDING. The frozen inventory below also includes this source report and its PDF. Counts are net adjacent-diff counts, including tests, documentation and the Python gitlink. They do not sum overlapping historical commits. The PR body records the final report-containing head.

Tracked path	Added	Deleted	Change and evidence
deps/python-keepkey	1	1	Pins the matching compiler mirror and its tests.
docs/release/audit-units/715-07b2-groups-audit-20260926.md	119	0	Records exact scope, findings, inventory and validation.
docs/release/audit-units/715-07b2-groups-audit-20260926.pdf	-	-	Rendered audit evidence from the adjacent source report.
docs/security/HANDOFF-ERC7730-715-FORMATTERS.md	18	0	Records on-screen behavior and fail-closed limits.
include/keepkey/firmware/erc7730_capabilities.h	15	7	Declares bounded state and the phase's runtime contract.
include/keepkey/firmware/erc7730_catalog.h	10	0	Declares bounded state and the phase's runtime contract.
include/keepkey/firmware/erc7730_workflow.h	13	0	Declares bounded state and the phase's runtime contract.
lib/firmware/erc7730_abi_stream.c	14	0	Captures only bounded ABI facts and records overflow.
lib/firmware/erc7730_capabilities.c	9	1	Selects the exact formatter and display capabilities.
lib/firmware/erc7730_catalog.c	73	12	Refuses unexecutable signed programs before review.
lib/firmware/erc7730_workflow.c	22	2	Keeps replay, validation and UI state in sequence.
lib/firmware/fsm_msg_ethereum.h	88	7	Shows and confirms the device-decoded review screens.
scripts/emulator/test_stack07_regressions.py	77	5	Exercises signed wire requests and review screens.
unittests/firmware/erc7730_catalog.cpp	151	15	Covers accepted neighbors and fail-closed boundaries.

Before D, the device refused group and iteration display instructions, so the official registry's array-backed descriptions could not be used. D checks array ownership before the first screen, counts elements in a validation pass and labels each element review. The same signed calldata is replayed for capture; a short

auxiliary array fails closed. The catalog, workflow and wire tests exercise both accepted arrays and adjacent refusal cases. The compiler mirror is checked against the device validator.

3. Current-source findings and limits

Finding	Disposition and evidence
D10 parallel arrays	Every source-1 formatter argument must walk the active array. A separate auxiliary array is refused before review; a short active array fails closed during capture. The validator and mirror controls document this limit.
D14 iteration title	Each element uses a device-owned <code>Signer field i of N title</code> , distinct from the signer label.
D18 fixed index in a dynamic array	Preload cannot know its length; capture fails closed if the index is absent. The wire case documents this limit.
Copilot round 1 scalar reuse	The verifier and host mirror require the formatter value to walk the active array. Native catalog and Python/firmware negative controls pass.
Copilot round 2 display frame aliasing	A dedicated <code>display_frames</code> array prevents group and iteration frames from overwriting path classes. <code>DisplayFramesPreservePathClasses</code> passes.
Split Copilot round 1 auxiliary formatter paths	Every source-1 argument must use the value path's active array. A same-array token address is accepted; another array or a scalar token path is refused by the firmware validator and Python mirror.
Split Copilot round 1 count error path	The captured count is decoded only after capture and class/length validation; a failed capture cannot read uninitialized bytes.
Split Copilot round 2 stale handoff count	The Phase D status now states 1,273 signable of 1,450 registry formats after 21 mixed-array refusals, matching the full local registry test.
Split Copilot round 3 fixed-array iteration coverage	<code>payFixed(address[2] recipients)</code> now checks both device-owned element titles and address screens beside the dynamic and empty-array cases. It passed against the local emulator.

The historical audit preserved D1–D19 clusters rather than all 42 raw rows; the top split receipt maps the surviving groups and names the evidence gap. The two historical D findings and both split round-1 findings are repaired in this code-bearing unit. Physical-device and release-promotion checks remain separate gates.

4. Verification and artifacts

Check	Exact source or run	Result and limit
Full native firmware	source-equivalent D code before report	firmware-unit 652/652 passed in a clean run directory.
Focused iteration controls	same code	<code>PreloadChecksIterationAgainstTheArrayItWalks, DisplayFramesPreservePathClasses and IterationPathsReachTheirArrayThroughTuples0</code> only pass.
Host/device mirror	Python 9ded843, rebuilt D validator	14 compiler cases pass, 3 skip without local evidence inputs; the full official registry has 1,450 formats and 1,273 signable after 21 mixed-array refusals.
Corrected cppcheck	D source, Ubuntu 24.04 CI flags	Zero findings.
Corrected hosted split run	GitHub Actions 36284789453, pre-fixed-array-test head	All required jobs passed at the corrected 1,273 registry count. The fixed-array test requires exact-head CI.
Wire and physical device	98bf4d20f local emulator	Dynamic, empty and fixed two-element arrays show the expected numbered screens; fixed-array case passed locally. Physical device not used.

Canonical preflight passed submodule cleanliness, unit-test registration and clang-format 20. It failed on inherited duplicate Osmosis/Solana nanopb options, `scripts/test_generate_test_report.py` absent from the 7a base, and its own missing `.cppcheck-build` directory. The owner approved the 7b push with this exception recorded. The gate is not called passing.

5. Report preflight and review checkpoint

The readable source and PDF contain the same inventory. The PDF was opened and checked for legibility. The final PR head and live target SHA belong in the PR body after this report commit. `git diff --check` and clang-format 20 pass. All three split Copilot rounds found issues; the third fixed-array test is repaired in 98bf4d20f. The main-worktree SOP requires a further split after three failed rounds. The existing D PR is preserved while

the owner reviews a concrete groups/visibility and iteration split. No fourth review is requested on this unsplit D PR.